

# Threat Prioritization Candidate Ranking Procedure

## Revision

Version 3  
8/11/26 1:56 PM

## Author

Charles Wilson

## Abstract

This document describes the procedure used to perform the threat candidate ranking activity described in the **AVCDL** <sup>[1]</sup> **Threat Prioritization Plan** <sup>[2]</sup> secondary document.

## Group / Owner

Security / Security Architect

## Motivation

This document is motivated by the need to have formal processes in place regarding the disposition of cybersecurity-related threats in the context of the development of safety-critical, cyber-physical systems.

**Note:** Within the context of this document, the terms **security** and **cybersecurity** are used interchangeably. It is presumed that the term **security** is being used in reference to **cybersecurity** and not **physical security**.

## License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

## Audience

The audience of this document is the cybersecurity practitioner who will be conducting the threat candidate ranking activity within the threat prioritization process.

## Completeness of Output

Since threat candidate ranking is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the security SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

When information is not available for either a given section of the template or parts thereof, this should be noted. Major omissions should be recorded in the cybersecurity risk register.

## Disposition of Output

The output of this activity is used as input to the **threat candidate risking** activity.

This activity does not generate any materials used as documents of record.

# Entry Criteria

This document assumes that the reader understands the purpose of threat candidate ranking. Further, that the reader has read and understood the AVCDL **Threat Prioritization Plan** secondary document.

## Prerequisites – Security SME

### Qualifications

It is required that the security SME is both a qualified and trained security architect (shown above on title page as **Owner**) as defined by the **NIST NCWF** role SP-ARC-002 and detailed in the **NCWF Roles - Security Architect** section of the **AVCDL Background Material** elaboration document [\[3\]](#).

### Knowledge

It is required that the security SME understands the purpose of threat candidate ranking.

### Background Information

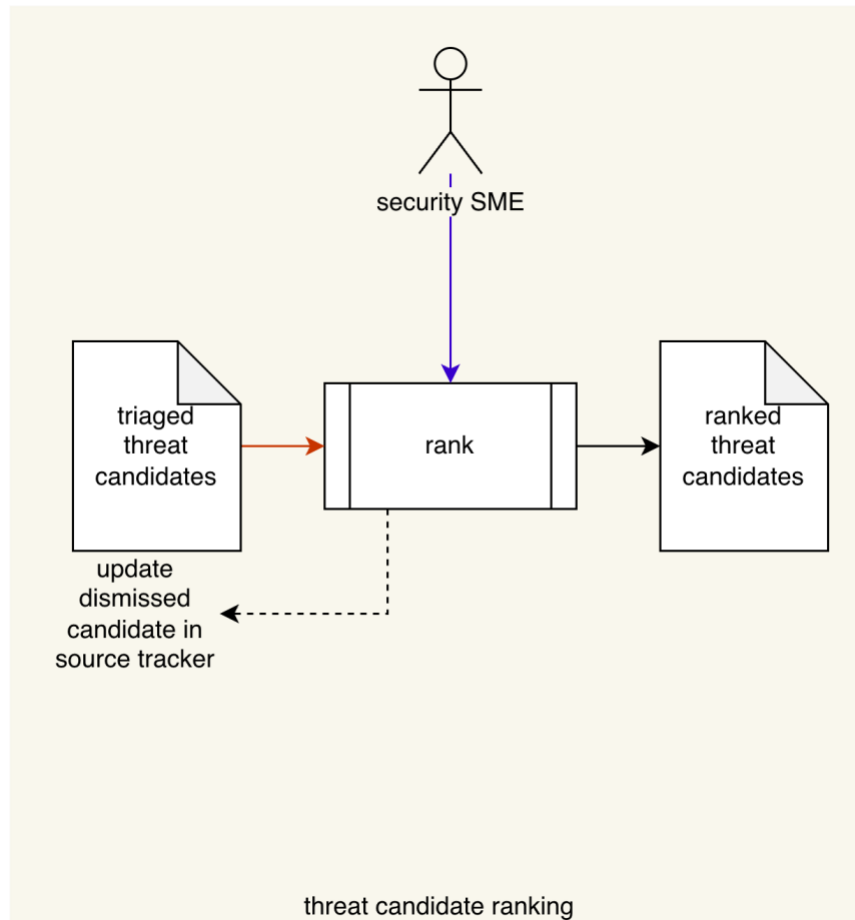
It is required that the security SME has read and understands the AVCDL **Threat Prioritization Plan** secondary document. Additionally, that the security SME has taken training relevant to this activity.

## Prerequisites – Input Materials

It is required that the security SME acquire any documentation relevant to the threat candidates under consideration necessary to complete the procedure.

# Candidate Ranking Activity

The workflow diagram for the **threat candidate ranking** activity of the **Threat Prioritization Plan** is shown below.



The **security SME** takes the **triaged threat candidates** and conducts a ranking on them to establish the likelihood of each. This produces a list of **ranked threat candidates**. Any threat candidates which are determined to be invalid are dismissed, and its source tracker is updated accordingly.

**Note:** A standard rubric should be used for determination of the threat likelihood.

**Note:** Some threat candidates may already have a likelihood provided. This is usually the case where the threat candidate comes from an outside source, such as a researcher or cybersecurity monitoring of vulnerability reporting databases. In these cases, the provided likelihood (numeric or quantized) will need to be mapped into the organizations quantization.

# Methodology

The recommended methodology for this activity is as follows:

1. Select a likelihood rubric
2. Encode the rubric quantization bands
3. Encode the domain quantization bands
4. Enumerate the threat candidates with minimal necessary details
5. Provide a worst case scenario for each threat candidate
6. Compute and record the rubric value and metadata for each threat candidate
7. Provide notes where appropriate

# Discussion

This section provides additional information to assist in performing this activity.

## Likelihood Rubric

The rubric used to determine a threat candidate's likelihood should be appropriate to the nature of the threat.

Some common rubrics are:

| Rubric              |                                     | Application               |
|---------------------|-------------------------------------|---------------------------|
| CVSS <sup>[5]</sup> | Common Vulnerability Scoring System | Defects in implementation |
| CCSS <sup>[6]</sup> | Common Configuration Scoring System | Defects in configuration  |
| CMSS <sup>[7]</sup> | Common Misuse Scoring System        | Unintended use cases      |

A more general rubric is presented in tables **G-2 – 4** of **NIST SP 800-30 Guide for Conducting Risk Assessments** <sup>[9]</sup>. Table **G-5** of the same document shows how to create an overall likelihood by combining the results from the other tables.

**Note:** Use of a purely quantized rubric (such as presented in **NIST SP 800-30**) can greatly simplify the threat prioritization process. It is highly recommended for organization where there is little history of formal cybersecurity threat prioritization.

## Likelihood Value and Quantization

When the chosen rubric generates a numeric value, it is useful to quantize that value in order to simplify the eventual determination of whether the threat candidate is controlled or uncontrolled.

The first three rubrics mentioned (CVSS, CCSS, and CMSS) produce a numeric score (value) which in the range [0,10]. They also provide a quantization shown below.

| CVSS score  | 0    | 0+  | 1 | 2 | 3 | 4      | 5 | 6 | 7    | 8 | 9        | 10 |
|-------------|------|-----|---|---|---|--------|---|---|------|---|----------|----|
| CVSS rating | none | low |   |   |   | medium |   |   | high |   | critical |    |

**Note:** The quantization for CCSS and CMSS is the same as for CVSS.

The use of quantization enables a simpler mechanism for processing the threat candidates in later activities.

**Note:** A true **zero** value and **none** quantization have been added in order to make it easier to implement automation.

Because a domain may have specific requirements regarding the documentation of likelihood (and in later activities, severity quantization), it is important to establish a mapping between the chosen rubric and domain quantization.

For example, if we consider the automotive domain, **ISO/SAE 21434 Road vehicles – Cybersecurity engineering** <sup>[8]</sup> specifies a likelihood (attack feasibility rating) quantization list (**very low**, **low**, **medium**, and **high**), shown below mapped to the CVSS rating.

| CVSS score    | 0    | 0+       | 1 | 2 | 3 | 4      | 5 | 6 | 7      | 8 | 9        | 10 |
|---------------|------|----------|---|---|---|--------|---|---|--------|---|----------|----|
| CVSS rating   | none | low      |   |   |   | medium |   |   | high   |   | critical |    |
| ISO/SAE 21434 | none | very low |   |   |   | low    |   |   | medium |   | high     |    |

Since ISO/SAE 21434 does not specify the value ranges (bands) for the quantization, they have been mapped to align with the ones provided for CVSS.

It is important to document the rationale for establishment of a mapping between the chosen likelihood rubric and domain quantization.

**Note:** As above, a true **zero** value and **none** quantization have been added in order to make it easier to implement automation.

## Likelihood (SP 800-30 Rubric)

Unlike rubrics that generates a numeric value, the likelihood rubric provided by NIST SP 800-30 works directly with quantized values. It provides semi-qualitative values that can be used to visualize the distribution of the quantization and also perform compositing in order to generate an overall likelihood of the threat candidate.

For comparison purposes, a visualization of SP 800-30 given the same treatment as with CVSS is shown below.

| 800-30 score  | 0    | 0+       | 10  | 20       | 30 | 40 | 50 | 60 | 70 | 80     | 90        | 100 |
|---------------|------|----------|-----|----------|----|----|----|----|----|--------|-----------|-----|
| 800-30 rating | none | very low | low | moderate |    |    |    |    |    | high   | very high |     |
| ISO/SAE 21434 | none | very low |     | low      |    |    |    |    |    | medium | high      |     |

One take away from this is that mapping from specific rubrics to domain quantizations does not guarantee correspondence across various likelihood rubrics.

An interesting feature of SP 800-30 is that it considers both adversarial and non-adversarial cases. The first being the likelihood of threat event initiation. The second being the likelihood of threat event occurrence. It separately considers the likelihood that the threat results in an adverse impact.

The following table shows how SP 800-30 defines the various likelihood quantization bands for each of these.

|                  | initiation      | occurrence          | adverse impact  |
|------------------|-----------------|---------------------|-----------------|
| <b>very high</b> | almost certain  | > 100 times / year  | almost certain  |
| <b>high</b>      | highly likely   | 10-100 times / year | highly likely   |
| <b>moderate</b>  | somewhat likely | 1-10 times / year   | somewhat likely |
| <b>low</b>       | unlikely        | > 1 time / 10 years | unlikely        |
| <b>very low</b>  | highly unlikely | < 1 time / 10 years | highly unlikely |



SP 800-30 then takes either the initiation or occurrence value (depending on the type) and impact value and composites them to generate an overall likelihood as shown below.

|                                           |           | likelihood of adverse impacts |          |          |           |           |
|-------------------------------------------|-----------|-------------------------------|----------|----------|-----------|-----------|
| likelihood of<br>initiation or occurrence |           | very low                      | low      | moderate | high      | very high |
|                                           | very high | low                           | moderate | high     | very high | very high |
|                                           | high      | low                           | moderate | moderate | high      | very high |
|                                           | moderate  | low                           | low      | moderate | moderate  | high      |
|                                           | low       | very low                      | low      | low      | moderate  | moderate  |
|                                           | very low  | very low                      | very low | low      | low       | low       |

## Worst Case Scenario

Most product cybersecurity threat candidates are identified at a level far below that of the system level. Because of this, it is extremely helpful to provide a possible system-level worst case scenario that may occur if a threat candidate is realized. This greatly assists the risk SME who will be providing a severity for the threat candidate in the context of the system itself. The risk SME should be able to readily determine whether the threat candidate has applicability to their risk domain.

# Threat Candidate Ranking Template

## (Numeric Rubric)

The threat candidate ranking may be documented using the **AVCDL threat candidate ranking template** Microsoft Excel workbook [\[3\]](#).

**Note:** Other forms of documentation are permissible so long as they provide the information laid out in this document.

**Note:** This template assumes the use of a likelihood rubric that generates numeric values. When a purely quantized rubric is used, the template may be simplified accordingly.

There workbook contains the following sheets:

- [Cover sheet](#)
- [Revision history](#)
- [Reference documents](#)
- [Ranking](#)
- [Rubric quantization](#)
- [Domain quantization](#)
- [Legend](#)

These will be addressed in turn.

## Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks and inter-sheet lookups may be attached to some of the cells which enables the use of dropdown lists and auto-population.

## Cover Sheet

The **cover sheet** of the workbook is shown below:

| Threat Candidate Ranking |                   |  |  |  |  |  |  |
|--------------------------|-------------------|--|--|--|--|--|--|
| Cybersecurity SME        | Cybersecurity SME |  |  |  |  |  |  |
| Likelihood Rubric        | Rubric            |  |  |  |  |  |  |
| Date                     | 27-Aug-2000       |  |  |  |  |  |  |
| Revision                 | 1                 |  |  |  |  |  |  |

Fields to be completed are shown in **red**.

### Cybersecurity SME

This is the cybersecurity subject matter expert creating the threat candidate ranking list.

### Likelihood Rubric

This is the name of the rubric used to determine the threat candidate's likelihood.

### Date

This is the date when the document was created or updated. The date should be updated whenever the document is updated.

### Revision

This is the revision number of the document. The revision number is a monotonic and increasing integer, starting at 1. It should be incremented every time the document is updated.

## Revision History

The **revision history** sheet of the workbook is shown below:

| Revision History |        |                  |
|------------------|--------|------------------|
| Revision         | Author | Description      |
| 1                |        | initial revision |
|                  |        |                  |
|                  |        |                  |
|                  |        |                  |

### Revision

The **revision** corresponds to that listed on the cover sheet.

### Author

The **author** corresponds to the cybersecurity SME listed on the cover sheet.

### Description

This is a brief description of changes made to the workbook since it was last updated.

## Reference Documents

**Note:** These references are those necessary for the creation of the threat candidate ranking list.

**Note:** References to information for both the rubric used and domain quantization should be included.

These entries are shown in **red**.

The **references** sheet of the workbook is shown below:

| Reference Documents      |                                           |                                   |
|--------------------------|-------------------------------------------|-----------------------------------|
| Name                     | Description                               | Location                          |
| rubric name              | rubric description                        | rubric reference URL              |
| domain quantization name | domain quantization reference description | domain quantization reference URL |
|                          |                                           |                                   |
|                          |                                           |                                   |

### Name

This is the name of the document being referenced.

### Description

This is a brief description of the document being referenced.

**Note:** In cases where the reference material is expressed in the form other than a document (for example, a web page), this should be noted.

### Location

This is the location of the document being referenced. It may be a physical location or a URL.

## Ranking

The **ranking** sheet of the workbook is shown below:

| Ranking      |             |         |            |                 |              |                     |                     |       |
|--------------|-------------|---------|------------|-----------------|--------------|---------------------|---------------------|-------|
| candidate ID | description | element | worst case | rubric metadata | rubric value | rubric quantization | domain quantization | notes |
|              |             |         |            |                 |              | none                | none                |       |
|              |             |         |            |                 |              | none                | none                |       |
|              |             |         |            |                 |              | none                | none                |       |
|              |             |         |            |                 |              | none                | none                |       |

### Candidate ID

This is the unique ID of the threat candidate.

**Note:** This value should be copied from the triage output providing input to this activity.

### Description

This a description of the threat candidate.

**Note:** This value should be copied from the triage output providing input to this activity.

### Element

This is the name of the element within the system where the threat candidate originates.

**Note:** This field is provided to give context to the threat candidate.

### Worst Case

This is a worst case scenario assuming the threat is realized.

### Rubric Metadata

This is a text representation of the inputs (parametrics) needed to replicate the rubric's output value generation.

### Rubric Value

This is generated output from the likelihood rubric.

## Rubric Quantization

This is the quantization of the likelihood rubric's output value as defined by the rubric.

**Note:** This field is auto-populated based on information in the **rubric quantization** sheet.

This field should not be altered manually.

## Domain Quantization

This is the quantization of the likelihood rubric's output value as mapped into the target domain.

**Note:** This field is auto-populated based on information in the **domain quantization** sheet.

This field should not be altered manually.

## Notes

This is a general notes field.



## Rubric Quantization

This sheet provides translation between the rubric value and its quantized representation.

Label selection is based on the bands minimum value, eliminating the need for including an upper bound.

The **rubric quantization** sheet of the workbook is shown below:

| Rubric Quantization |       |                           |                          |
|---------------------|-------|---------------------------|--------------------------|
| min value           | label | description               | notes                    |
| 0.0000              | none  | used to enable automation | DO NOT REMOVE THIS ENTRY |
| 0.0001              |       |                           |                          |
|                     |       |                           |                          |
|                     |       |                           |                          |

**Note:** A true zero (none) entry is pre-populated in order to support automation.

### Min Value

This is the minimum value of the quantization band.

**Note:** The second entry pre-populates this value to be slightly greater than the '**none**' band.

### Label

This is the name of the quantization band.

**Note:** This column is used to populate the **rubric quantization** field on the **ranking** sheet corresponding to the **rubric value** entry.

### Description

This is the description of the quantization band.

### Notes

This is a general notes field.

## Domain Quantization

This sheet provides translation between the rubric value and the target domain's quantized representation.

Label selection is based on the bands minimum value, eliminating the need for including an upper bound.

The **domain quantization** sheet of the workbook is shown below:

| Domain Quantization |       |                           |                          |
|---------------------|-------|---------------------------|--------------------------|
| min value           | label | description               | notes                    |
| 0.0000              | none  | used to enable automation | DO NOT REMOVE THIS ENTRY |
| 0.0001              |       |                           |                          |
|                     |       |                           |                          |
|                     |       |                           |                          |

**Note:** A true zero (none) entry is pre-populated in order to support automation.

### Min Value

This is the minimum value of the quantization band.

**Note:** The second entry pre-populates this value to be slightly greater than the '**none**' band.

### Label

This is the name of the quantization band.

**Note:** This column is used to populate the **domain quantization** field on the **ranking** sheet corresponding to the **rubric value** entry.

### Description

This is the description of the quantization band.

### Notes

This is a general notes field.

## Legend

**Note:** This workbook does not use the legend sheet.

# Threat Candidate Ranking Template (NIST SP 800-30 Rubric)

The threat candidate ranking may be documented using the **AVCDL threat candidate ranking (SP 800-30) template** Microsoft Excel workbook [\[10\]](#) when the NIST SP 800-30 rubric is used.

**Note:** Other forms of documentation are permissible so long as they provide the information laid out in this document.

There workbook contains the following sheets:

- Cover sheet
- Revision history
- Reference documents
- [Ranking](#)
- [800-30 quantization](#)
- Legend

Because this template is a variant of the previously discussed one, only the **ranking** and **quantization** sheets will be covered.

## Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks and inter-sheet lookups may be attached to some of the cells which enables the use of dropdown lists and auto-population.

## Ranking (SP 800-30)

The **ranking** sheet of the workbook is shown below:

| Ranking      |             |         |            |                 |                         |                |                    |       |
|--------------|-------------|---------|------------|-----------------|-------------------------|----------------|--------------------|-------|
| candidate ID | description | element | worst case | rubric metadata | initiation / occurrence | adverse impact | overall likelihood | notes |
|              |             |         |            | N/A             | none                    | none           | none               |       |
|              |             |         |            | N/A             | none                    | none           | none               |       |
|              |             |         |            | N/A             | none                    | none           | none               |       |
|              |             |         |            | N/A             | none                    | none           | none               |       |

### Candidate ID

This is the unique ID of the threat candidate.

**Note:** This value should be copied from the triage output providing input to this activity.

### Description

This a description of the threat candidate.

**Note:** This value should be copied from the triage output providing input to this activity.

### Element

This is the name of the element within the system where the threat candidate originates.

**Note:** This field is provided to give context to the threat candidate.

### Worst Case

This is a worst case scenario assuming the threat is realized.

### Rubric Metadata

This is a text representation of the inputs (parametrics) needed to replicate the rubric's output value generation.

**Note:** This field is included for consistency and is pre-populated with **N/A**.

## Initiation / Occurrence

This is the quantization of the likelihood of either the initiation (adversarial) or occurrence (non-adversarial) of the threat candidate.

**Note:** This field is auto-populated based on information in the **800-30 quantization** sheet. Values are based on information from NIST SP 800-30.

This field should not be altered manually.

## Adverse Impact

This is the quantization of the likelihood that the threat candidate has an adverse impact should it be realized.

**Note:** This field is auto-populated based on information in the **800-30 quantization** sheet. Values are based on information from NIST SP 800-30.

This field should not be altered manually.

## Overall Likelihood

This is the quantization of the overall likelihood as determined by compositing the **initiation / occurrence** and **adverse impact** values.

**Note:** This field is calculated based on the **initiation / occurrence** and **adverse impact** fields based on information specified in NIST SP 800-30.

This field should not be edited.

## Notes

This is a general notes field.

## 800-30 Quantization

This sheet provides translation between the rubric value and its quantized representation.

**Note:** This sheet (based on NIST SP 800-30) is complete and should not be modified.

The **800-30 quantization** sheet of the workbook is shown below:

| 800-30 Rubric Quantization |           |                   |                           |                          |
|----------------------------|-----------|-------------------|---------------------------|--------------------------|
| min value                  | label     | compositing value | description               | notes                    |
| 0.0000                     | none      | 0.0000            | used to enable automation | DO NOT REMOVE THIS ENTRY |
| 0.0001                     | very low  | 1                 |                           |                          |
| 5.0000                     | low       | 2.5               |                           |                          |
| 21.0000                    | moderate  | 8                 |                           |                          |
| 80.0000                    | high      | 9.6               |                           |                          |
| 96.0000                    | very high | 10                |                           |                          |

**Note:** A true zero (none) entry is pre-populated in order to support automation.

### Min Value

This is the minimum value of the quantization band.

**Note:** The second entry pre-populates this value to be slightly greater than the '**none**' band.

**Note:** The values of this field are assigned in order to generate the qualitative values specified in NIST SP 800-30 appendix G.

### Label

This is the name of the quantization band.

**Note:** This column is used to populate fields on the **ranking** sheet corresponding. It is used for both drop-down lists and computed fields.

### Compositing Value

This value is used to create an overall likelihood based on the **initiation / occurrence** and **adverse impact** fields.

**Note:** The values of this field are assigned in order to generate composite values specified in NIST SP 800-30 table G-5.

## Description

This is the description of the quantization band.

## Notes

This is a general notes field.



## Exit Criteria

This procedure is considered complete once the **ranked threat candidates** list has been generated.

**Note:** This activity does not generate any materials used as documents of record.

# References

1. **AVCDL** (AVCDL primary document)
2. **Theat Prioritization Plan** (AVCDL secondary document)
3. **AVCDL Background Material** (AVCDL elaboration document)
4. **AVCDL threat candidate ranking template** (AVCDL template)
5. **Common Vulnerability Scoring System**  
<https://www.first.org/cvss/>
6. **The Common Misuse Scoring System (CMSS): Metrics for Software Feature Misuse Vulnerabilities**  
[https://tsapps.nist.gov/publication/get\\_pdf.cfm?pub\\_id=910230](https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=910230)
7. **The Common Configuration Scoring System (CCSS): Metrics for Software Security Configuration Vulnerabilities**  
<https://nvlpubs.nist.gov/nistpubs/legacy/ir/nistir7502.pdf>
8. **ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering**  
<https://www.iso.org/standard/70918.html>
9. **NIST SP 800-30 r1 – Guide to Conducting Risk Assessments**  
<http://dx.doi.org/10.6028/NIST.SP.800-30r1>
10. **AVCDL threat candidate ranking (SP 800-30) template** (AVCDL template)